

RAPPORT TP 3.2 — Attaque d'un système Windows et extraction d'identifiants

Objectif du TP

Comprendre comment un attaquant peut compromettre une machine Windows via :

- L'exploitation de services mal configurés (SMB)
- L'utilisation d'identifiants faibles
- L'extraction d'informations sensible

Vérification de l'accessibilité de la cible

```
kali linux [En fonction] - Oracle VM VirtualBox
Fichier Machine Écran Entrée Périphériques Aide
1 2 3 4

(aquilas@kali)-[~]
$ ping 192.168.56.20
PING 192.168.56.20 (192.168.56.20) 56(84) bytes of data.
64 bytes from 192.168.56.20: icmp_seq=1 ttl=128 time=0.493 ms
64 bytes from 192.168.56.20: icmp_seq=2 ttl=128 time=0.684 ms
64 bytes from 192.168.56.20: icmp_seq=3 ttl=128 time=1.30 ms
64 bytes from 192.168.56.20: icmp_seq=4 ttl=128 time=0.827 ms
64 bytes from 192.168.56.20: icmp_seq=5 ttl=128 time=0.857 ms
^C64 bytes from 192.168.56.20: icmp_seq=6 ttl=128 time=0.700 ms
64 bytes from 192.168.56.20: icmp_seq=7 ttl=128 time=0.566 ms
64 bytes from 192.168.56.20: icmp_seq=8 ttl=128 time=0.948 ms
^C
— 192.168.56.20 ping statistics —
8 packets transmitted, 8 received, 0% packet loss, time 7084ms
rtt min/avg/max/mdev = 0.493/0.797/1.302/0.237 ms

(aquilas@kali)-[~]
$
```

Identification des services Windows exposés

```
(aquilas@kali)-[~]
$ nmap 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-26 20:46 +0200
Nmap scan report for 192.168.56.20
Host is up (0.00041s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
MAC Address: 08:00:27:E6:E8:25 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 5.73 seconds

(aquilas@kali)-[~]
$
```

🚩 Récolte d'informations système sans authentification

nmap -p 445 --script smb-os-discovery 192.168.56.20

```
(aquilas@kali)-[~]
$ nmap -p 445 --script smb-os-discovery 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-26 21:27 +0200
Nmap scan report for 192.168.56.20
Host is up (0.00056s latency).

PORT      STATE SERVICE
445/tcp    open  microsoft-ds
MAC Address: 08:00:27:AA:C6:11 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 4.26 seconds
```

La commande n'affiche aucune information sur l'Os car la machine cible bloque les requêtes d'énumération SMB. De ce fait on utilise la commande `sudo nmap -p 445 -A 192.168.56.20` pour forcer la detection des informations sur l'os

```
(aquilas@kali)-[~]
$ sudo nmap -p 445 -A 192.168.56.20
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-27 08:11 +0200
Nmap scan report for 192.168.56.20
Host is up (0.0011s latency).

PORT      STATE SERVICE      VERSION
445/tcp    open  microsoft-ds?
MAC Address: 08:00:27:AA:C6:11 (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Microsoft Windows 10
OS CPE: cpe:/o:microsoft:windows_10
OS details: Microsoft Windows 10 1709 - 21H2
Network Distance: 1 hop

Host script results:
|_ smb2-time:
|   date: 2026-04-27T05:11:33
|_ start_date: N/A
|_ nbstat: NetBIOS name: DESKTOP-3JE7S1M, NetBIOS user: <unknown>, NetBIOS MAC: 08:00:27:aa:c6:11 (Oracle VirtualBox virtual NIC)
|_ clock-skew: -1h00m01s
|_ smb2-security-mode:
|   3.1.1:
|_ Message signing enabled but not required

TRACEROUTE
HOP RTT ADDRESS
1 1.15 ms 192.168.56.20

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 18.32 seconds
```

🚩 Tentative d'accès à un partage

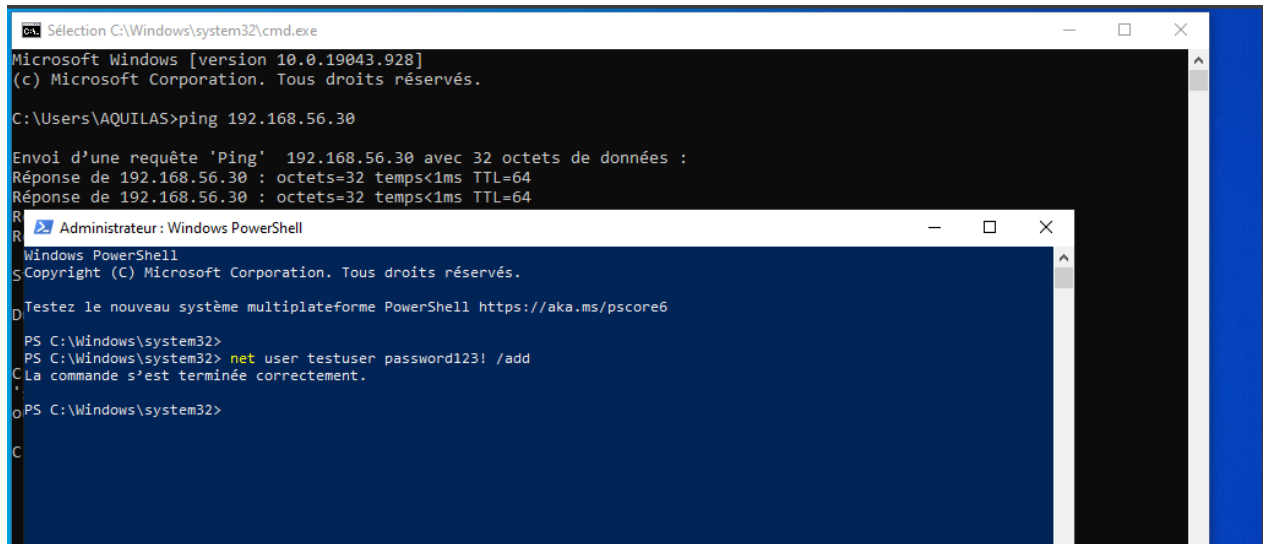
smbclient //192.168.56.20/ShareDocs -N

ls

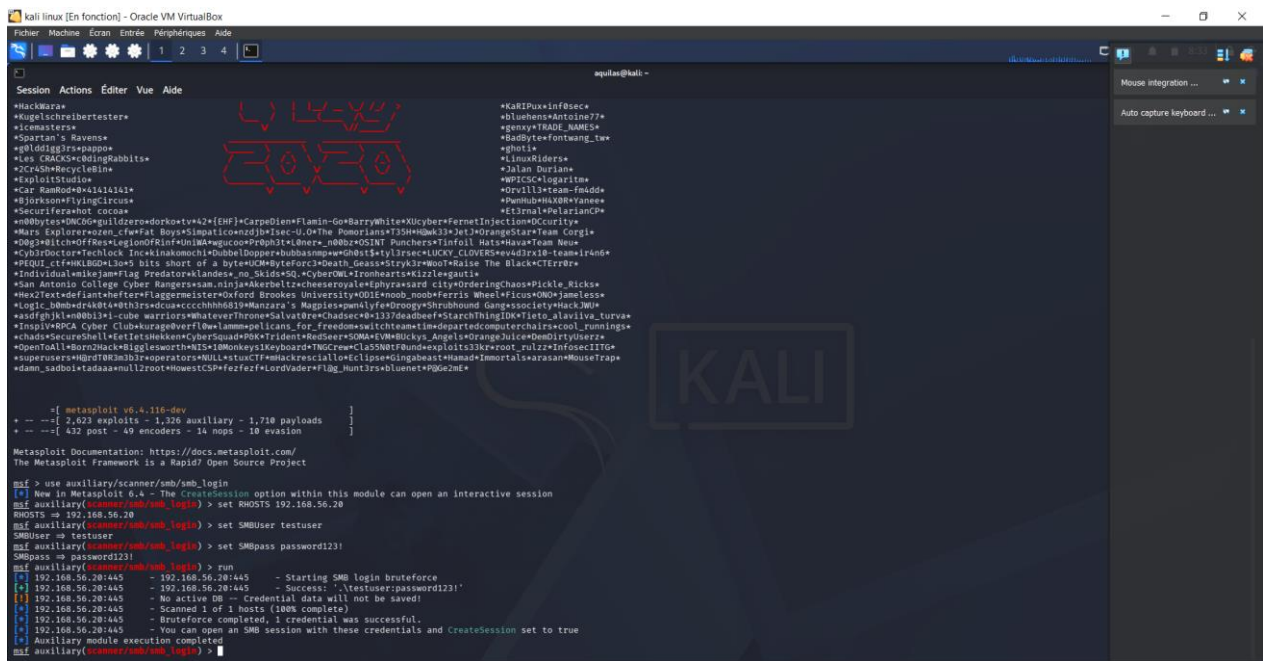
```
(aquilas@kali)-[~]
$ smbclient -L //192.168.56.20 -N
session setup failed: NT_STATUS_ACCESS_DENIED
```

La cible interdit l'accès anonyme : c'est la configuration par défaut de Windows depuis 2008

Création d'un compte vulnérable (sur Windows cible)



Test de connexion avec Metasploit



1. Découverte → nmap pour identifier SMB
2. Information → smb-os-discovery pour version Windows
3. Accès initial → smbclient partage sans auth
4. Authentification → testuser:Password123!
5. Compromission → psexec + Meterpreter
6. Post-exploitation → hashdump, screenshot, keylogging

Conclusion

Ce travail pratique m'a permis de comprendre :

1. **La compromission ne nécessite pas toujours une vulnérabilité complexe** — Un mot de passe faible ou un partage mal configuré suffisent.
2. **SMB est un vecteur d'attaque critique** — Souvent mal configuré en entreprise.
3. **Post-exploitation = danger réel** — Une fois à l'intérieur, l'attaquant peut extraire identifiants, capturer écrans, enregistrer frappes.